Unit 6. Security in Networks: =>

6.1. Threats in networks

6.2 Network Security Controls

6.2.1. Architecture

6.2.2. Encryption

6.2.3. Content Integrity

6.2.4. Strong Authentication

6.2.5. Access Controls (Physical and Logical)

6.2.6. Wireless Security

6.2.7. Honeypots

6.2.8. Traffic flow security

6.3 Firewalls

6.3.1. Design and Types of Firewalls 6

6.3.2. Personal Firewalls

6.3.3. Intrusion Detection System (IDS) and its types

6.3.4. Intrusion Protection System (IPS)

6.4 Email Security

6.4.1. PGP

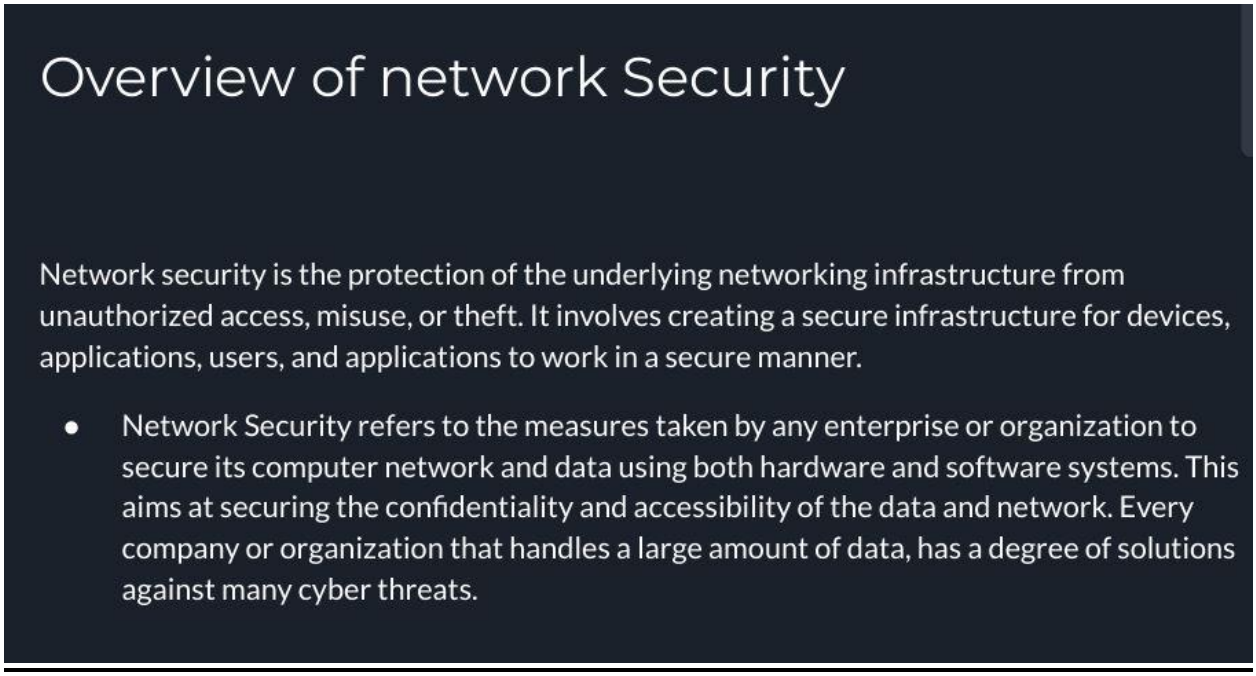
6.4.2. S/MIME

6.1. Threats in networks

Introduction of security network

:=>

Definition of network security: => Network security is the protection of the underlying networking infrastructure from unauthorized access, misuse, or theft. It involves creating a secure infrastructure for devices, applications, users, and applications to work in a secure manner**.**



- Network security is any activity designed to protect the usability and integrity of your network and data. It includes both hardware and software technologies
- . It targets a variety of threats. It stops them from entering or spreading on your network. Effective network security manages access to the network**.**
- Network Security protects your network and data from breaches, intrusions and other threats.

Notes:=>

- **Usability:** Usability in information security ensures that systems are easy to use and intuitive, enabling users to perform tasks securely without excessive effort or risk of error.

- **Accessibility:** Accessibility ensures that authorized users, including those with disabilities, can access information and resources whenever needed, with minimal disruption.
- **Integrity:** Integrity involves maintaining the accuracy and completeness of data, protecting it from unauthorized alterations, and ensuring its reliability for decision-making.

- This is a vast and overarching term that describes hardware and software solutions as well as processes or rules and configurations relating to network use, accessibility, and overall threat protection.

THREE ELEMENTS OF NETWORK SECURITY: =>

The CIA triad refers to an information security model made up of the three main components: confidentiality, integrity and availability. Each component represents a fundamental objective of information security**.**

Summary

Network security is the deployment and monitoring of cyber security solutions to protect your organization's IT systems from attacks and breaches. It also covers policies surrounding the handling of sensitive information.

Network security involves the following solutions:=>

Network segmentation

Data loss prevention (DLP)

Firewalls

Intrusion prevention systems (IPS)

What is a secured network?

When we discuss data and information, we must consider the CIA triad. The CIA triad refers to an information security model made up of the three main components: confidentiality, integrity and availability.

6.1. Threats in networks

	Threats	Consequences
Integrity	• Modification of user data • Trojan horse browser • Modification of memory • Modification of message traffic in transit	• Loss of information • Compromise of machine • Vulnerabilty to all other threats
Confidentiality	• Eavesdropping on the net • Theft of info from server • Theft of data from client • Info about network configuration • Info about which client talks to server	• Loss of information • Loss of privacy
Denial of Service	• Killing of user threads • Flooding machine with bogus requests • Filling up disk or memory • Isolating machine by DNS attacks	• Disruptive • Annoying • Prevent user from getting work done
Authentication	• Impersonation of legitimate users • Data forgery	• Misrepresentation of user • Belief that false information is valid

---

Explantion of above security threats:=>

Integrity

- **Threats**:
  - **Modification of user data**: Changing user information without permission.
  - **Trojan horse browser**: Malicious software disguised as a legitimate browser (A "Trojan horse browser" is a harmful program that pretends to be a normal, safe web browser but is actually designed to cause damage or steal information.)
  - **Modification of memory**: Unauthorized changes to the computer's memory.
  - **Modification of message traffic in transit**: Altering data being transmitted.
- **Consequences**:
  - **Loss of information**: Data gets corrupted or lost.
  - **Compromise of machine**: The computer becomes unsafe to use.
  - **Vulnerability to all other threats**: Increased risk of other security issues.

Confidentiality

- **Threats**:

Eavesdropping on the net: Spying on online communications.(Eavesdropping on the net" means secretly listening to or monitoring other people's online conversations and activities without their knowledge.

4o

    -)
    - **Theft of info from server**: Stealing data stored on a server.
    - **Theft of data from client**: Stealing data from a user's device.
    - **Info about network configuration**: Gaining unauthorized knowledge about network setup.
    - **Info about which client talks to server**: Knowing who is communicating with the server.
- **Consequences**:
    - **Loss of information**: Data is stolen or exposed.
    - **Loss of privacy**: Personal information is no longer private.

Denial of Service

- **Threats**:
    - **Killing of user threads**: Stopping user activities on a computer (Killing of user threads" means forcefully stopping or interrupting the activities or tasks that a user is doing on their computer where ("thread" refers to a single sequence of tasks or operations within a computer program that can be managed independently)
    - **Flooding machine with bogus requests**: Overloading a computer with fake requests.
    - **Filling up disk or memory**: Using up all storage or memory.
    - **Isolating machine by DNS attacks**: Cutting off the computer's access to the network.
- **Consequences**:
    - **Disruptive**: Interrupts normal computer operations.
    - **Annoying**: Causes frustration for users.
    - **Prevent user from getting work done**: Stops users from completing tasks.

Authentication

- **Threats**:
    - **Impersonation of legitimate users**: Pretending to be someone else.
    - **Data forgery**: Creating fake data.
- **Consequences**:
    - **Misrepresentation of user**: Incorrectly identifies users.
    - **Belief that false information is valid**: Trusting incorrect data

A network security threat is any malicious activity that compromises the confidentiality and integrity of online data and systems. It is performed by

individuals or groups hoping to gain unauthorized access to systems and steal data.

What are five internet security threats?

a. Malware
b. Ransomware
c. Distributed denial of service (DDoS) attacks
d. Spam and Phishing
e. MIM attacks
f. Viruses

Threat versus attacks

A network security threat is any malicious activity that compromises the confidentiality and integrity of online data and systems. It is performed by individuals or groups hoping to gain unauthorized access to systems and steal data.

Explanation of internet security threats:=>

a. **Malware: =>**
   Malware, short for malicious software, refers to any intrusive software developed by cybercriminals (often called hackers) to steal data and damage or destroy computers and computer systems. Examples of common malware include viruses, worms, Trojan viruses, spyware, adware, and ransomware.
b. **Ransomware: =>**

Ransomware is a form of malware designed to encrypt files on a device, rendering any files and the systems that rely on them unusable. Malicious actors then demand ransom in exchange for decryption. The ransom is often requested in cryptocurrencies like Bitcoin to maintain anonymity and avoid tracing. (keeping the identity and location of the malicious actors to prevent them from being tracked or identified by authorities where(**In the context of ransomware, "ransom" refers to the money demanded by cybercriminals from their victims to restore access to the victim's data or system.**

4o

)

c. **DDoS attacks :=>** An attack where multiple compromised systems are used to target a single system, causing a denial of service.

DDoS (Distributed Denial of Service) attack is primarily about overwhelming a system with excessive, unwanted traffic, making it unavailable to its intended users.

d. **Spam and Phishing:=>** Unsolicited messages (unwanted or spam) and attempts to obtain sensitive information by disguising as a trustworthy entity (phishing).

   Spam refers to unnecessary or irrelevant messages sent to a large number of people, often for advertising purposes. Phishing refers to deceiving individuals into providing sensitive information by pretending to be a legitimate and trustworthy entity.

e. **MItM:=>**

An attack where the attacker secretly intercepts and possibly alters the communication between two parties.

f. **Viruses: =>**

   A type of malware that replicates itself by modifying other computer programs and inserting its own code.

Unit 6. Security in Networks: =>

6.2 Network Security Controls

6.2.1. Architecture

6.2.2. Encryption

6.2.3. Content Integrity

6.2.4. Strong Authentication

6.2.5. Access Controls (Physical and Logical)

6.2.6. Wireless Security

6.2.7. Honeypots

6.2.8. Traffic flow security

6.2 Network security controls: =>

Network security is the protection of the underlying networking infrastructure from unauthorized access, misuse, or theft. It involves creating a secure

infrastructure for devices, applications, users, and applications to work in a secure manner.

Network security controls include:

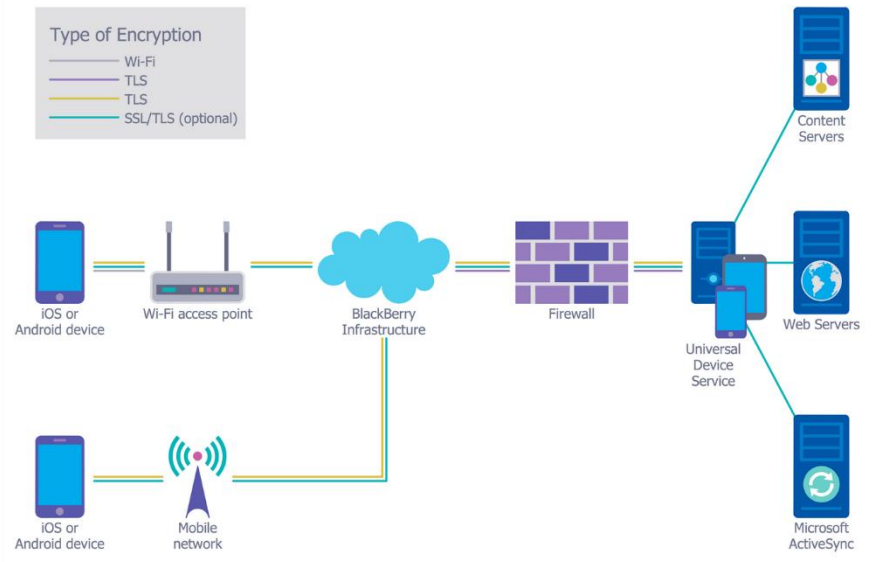
a. Access controls
b. Identification
c. Authentication
d. Authorization
e. Accounting

Network Security Controls are used to ensure the confidentiality, integrity, and availability of the network services. These security controls are either technical or administrative safeguards implemented to minimize the security risk.

6.2.1 Architecture: =>

A network security architecture provides a basis for an organization's cyber defenses and helps to protect all of the company's IT assets

Network security architecture refers to the design and structure of a network's security systems and protocols to protect against threats and unauthorized access. It encompasses various components and strategies, such as firewalls, intrusion detection systems, encryption, and secure access controls. This architecture is designed to safeguard the integrity, confidentiality, and availability of data and network resources.



This figure illustrates a network security architecture showing how data is securely transmitted between devices and servers. Here's a simple explanation and the working of this architecture:

Components:

1. **Devices**: iOS or Android devices.
2. **Wi-Fi Access Point**: The device connects to the network via a Wi-Fi router.
3. **Mobile Network**: Alternatively, the device can connect via a mobile network.
4. **BlackBerry Infrastructure**: A cloud service that processes and forwards data.
5. **Firewall**: A security system that monitors and controls incoming and outgoing network traffic.
6. **Servers**:
    - **Universal Device Service**: Manages communication between devices and other servers.
    - **Web Servers**: Host websites and web applications.
    - **Content Servers**: Store and provide access to data.
    - **Microsoft ActiveSync**: A service for syncing emails, calendars, and contacts.

Types of Encryption:

- **Wi-Fi**: Used when devices connect through a Wi-Fi access point.
- **TLS (Transport Layer Security)**: Ensures secure communication over the network.
- **SSL/TLS (Secure Sockets Layer/Transport Layer Security)**: Optional, provides additional security.

How It Works:

1. **Device Connection**:
    - A device (iOS or Android) connects to the network via Wi-Fi or a mobile network.
2. **Data Transmission**:
    - The data from the device is encrypted using Wi-Fi or mobile network encryption.
    - This data is sent to the BlackBerry Infrastructure for processing.
3. **Security Processing**:
    - The BlackBerry Infrastructure manages the data and forwards it securely.
    - Data passes through a firewall, which acts as a security barrier, filtering and monitoring traffic.
4. **Server Communication**:
    - The Universal Device Service manages the data flow between devices and the various servers.
    - Depending on the type of data, it may be sent to Web Servers, Content Servers, or Microsoft ActiveSync for further processing.

5. **Data Access**:
    - The servers process the data and send the necessary responses back through the same path, ensuring secure and efficient communication.

    Summary:

    This architecture ensures that data from mobile devices is securely transmitted to and from servers using various types of encryption and security measures like firewalls, managing communication and protecting sensitive information.

6.2.2. Encryption: =>

What is encryption in networking?

Encryption is a form of data security in which information is converted to cipher text. Only authorized people who have the key can decipher the code and access the original plaintext information. In even simpler terms, encryption is a way to render data unreadable to an unauthorized party.

In even simpler terms, encryption is a way to render data unreadable to an unauthorized party.

What is encryption security?

Encryption is used to protect data from being stolen, changed, or compromised and works by scrambling data into a secret code that can only be unlocked with a unique digital key.
This serves to protect cybercriminals, who may have used quite sophisticated means to gain access to a corporate network—only to find out that the data is unreadable and therefore useless.

Encryption not only ensures the confidentiality of data or messages but it also provides authentication and integrity, proving that the underlying data or messages have not been altered in any way from their original state.

Types of encryption

:=>

1. **Symmetric Encryption:** Uses the same key to both encrypt and decrypt data, like having one key that locks and unlocks a door.

2. **Asymmetric Encryption:** Uses two keys – a public key for encrypting data and a private key for decrypting it, similar to a mailbox where anyone can drop a letter in (public key) but only the owner can open it (private key).

3. **RSA**: A type of asymmetric encryption that uses large prime numbers to create public and private keys, widely used for secure data transmission.

4. **DES**: A symmetric encryption method that uses a fixed-length key to encrypt data in blocks, though now considered outdated and insecure.

5. **End-to-End Encryption**: Ensures that data is encrypted on the sender's device and only decrypted on the recipient's device, preventing anyone else (even service providers) from accessing the data during transmission.

Benefits of encryption:

a. **Privacy and security:** Encryption ensures that only authorized parties can access the information, protecting it from unauthorized access and breaches.

b. **Regulations:** Encryption helps organizations comply with data protection regulations and standards, avoiding legal penalties.

c. **Network browsing:** Encryption safeguards data transmitted over networks, protecting it from interception and tampering.

d. **Keeps sensitive data safe:** Encryption secures sensitive information, such as personal or financial data, from being accessed or misused by unauthorized individuals.

6.2.3. Content Integrity :=>

Content integrity refers to the process of managing and assuring the accurateness and correctness of the content being transferred or being made available to end users. In order to protect sensitive information, one of the services of confidentiality, integrity and availability has to be deployed.

Refers to the assurance that the data has not been altered or tampered with, maintaining its accuracy and consistency from creation to consumption. It's about ensuring the data remains unchanged and trustworthy.

6.2.4 Strong Authentication :=>

1. Multi-Factor Authentication (MFA):

What it is: MFA requires users to provide two or more verification factors to gain access to a resource such as an application, online account, or a VPN.

Factors involved:

a. Something you know: This could be a password or PIN.
b. Something you have: This could be a smart card, a security token, or a mobile phone with an authentication app.
c. Something you are: This involves biometrics like fingerprints, retina scans, or voice recognition.
d. Why it's strong: By requiring multiple forms of verification, MFA makes it significantly harder for attackers to gain access, even if they manage to compromise one of the factors.

2. Biometric Authentication:

a. What it is: This uses unique biological characteristics for verification, such as fingerprints, facial recognition, iris scans, or voice recognition.
b. Advantages: Biometrics are hard to replicate or steal compared to traditional passwords.
c. Implementation: Common in physical access controls, mobile devices, and secure areas within a network.

3. Token-Based Authentication:

a. What it is: Users are provided with a physical or software token that generates a time-sensitive code used for login.
b. Examples: Hardware tokens (like RSA SecurID tokens), software tokens (apps like Google Authenticator), and one-time passwords (OTPs).
c. Why it's strong: Tokens add an additional layer of security, requiring possession of the token along with the knowledge of the corresponding PIN or password.

4. Public Key Infrastructure (PKI):

What it is: PKI uses asymmetric cryptography, where a pair of keys (public and private) are used for encryption and decryption, ensuring secure communications.

Components: Digital certificates, Certificate Authorities (CAs), and Registration Authorities (RAs).

Advantages: Provides strong encryption and a robust method for verifying identities and securing communications.

Application: Often used for secure email (S/MIME), VPN access, and secure web transactions (HTTPS).

6. Smart Cards and Cryptographic Devices:

What it is: Smart cards are physical devices embedded with integrated circuits that can process data, often used for storing cryptographic keys and performing encryption/decryption.

Usage: Common in government and enterprise environments for physical and logical access control.

Strengths: Smart cards require both the physical card and a PIN, combining two-factor authentication with cryptographic security.

Importance of Strong Authentication in Network Access Controls

a. Enhanced Security: Strong authentication reduces the risk of unauthorized access, protecting against various attack vectors like phishing, brute force attacks, and credential stuffing.

b. Compliance: Many regulations and standards, such as GDPR, HIPAA, and PCI-DSS, require strong authentication mechanisms to ensure data protection and privacy.
c. User Accountability: Strong authentication helps in maintaining an accurate log of user activities, which is crucial for auditing and forensic analysis in case of a security incident.
d. Prevention of Data Breaches: By ensuring that only authenticated users can access sensitive information, strong authentication helps prevent data breaches and the associated financial and reputational damage.

In summary, strong authentication is a foundational element of network access controls in information security. It leverages multiple factors and advanced technologies to verify user identities, ensuring that only authorized individuals can access network resources. This significantly enhances the security posture of an organization and helps in protecting against various cyber threats.

6.2.5. Access Controls (Physical and Logical):=>

=> Physical security controls include such things as data center perimeter fencing, locks, guards, access control cards, biometric access control systems, surveillance cameras and intrusion detection sensors.

=> Logical access control limits connections to computer networks, system files and data.

Access control is a security technique that regulates who or what can view or use resources in a computing environment. It is a fundamental concept in security that minimizes risk to the business or organization. There are two types of access control: physical and logical. Physical access control limits access to campuses, buildings, rooms, and physical IT assets. Logical access control limits connections to computer networks, system files, and data. These are further explained below: =>

Logical Access Control

Logical Access Control is the ability and means to allow or deny logical or computer-based access to data of one kind or another. Keeping in mind the CIA of Cybersecurity (Confidentiality, Integrity, and Availability) logical access control typically pertains to Confidentiality – making sure only the people who should have access to something are the ones with access to that data set.

Physical Access Control

Physical Access Control is the ability and processes to grant and deny physical access to locations within a building, company, or even within a room at a company. Techniques can involve using RFID picture ID badges that must be worn and displayed by employees throughout your offices, to separate control entry points for server rooms. In high-security locations such as a data center, the use of ‘Man Trap‘ is a requirement, although, CyberHoot believes we should begin calling them ‘Person Trap‘ as we know quite a few exceptional social engineering experts who are most definitely not men.

6.2.6 Wireless security

Wireless security is the prevention of unauthorized access or damage to computers or data using wireless networks, which include Wi-Fi networks. The term may also refer to the protection of the wireless network itself from adversaries seeking to damage the confidentiality, integrity, or availability of the network.

Five elements of wireless security:=>

The five elements of a wireless network security solution are authentication, encryption, access control, intrusion detection and prevention, and security policies/procedures.

Wireless network security

:=>

Wireless network security is a subset of network security that involves designing, implementing, and ensuring security on wireless computer networks to protect them from unauthorized access and breaches. It involves strategies designed to preserve the confidentiality, integrity, and availability of wireless networks and their resources. Effectively implementing proper security strategies prevents threats like interception, data theft, and denial-of-service attacks from occurring.

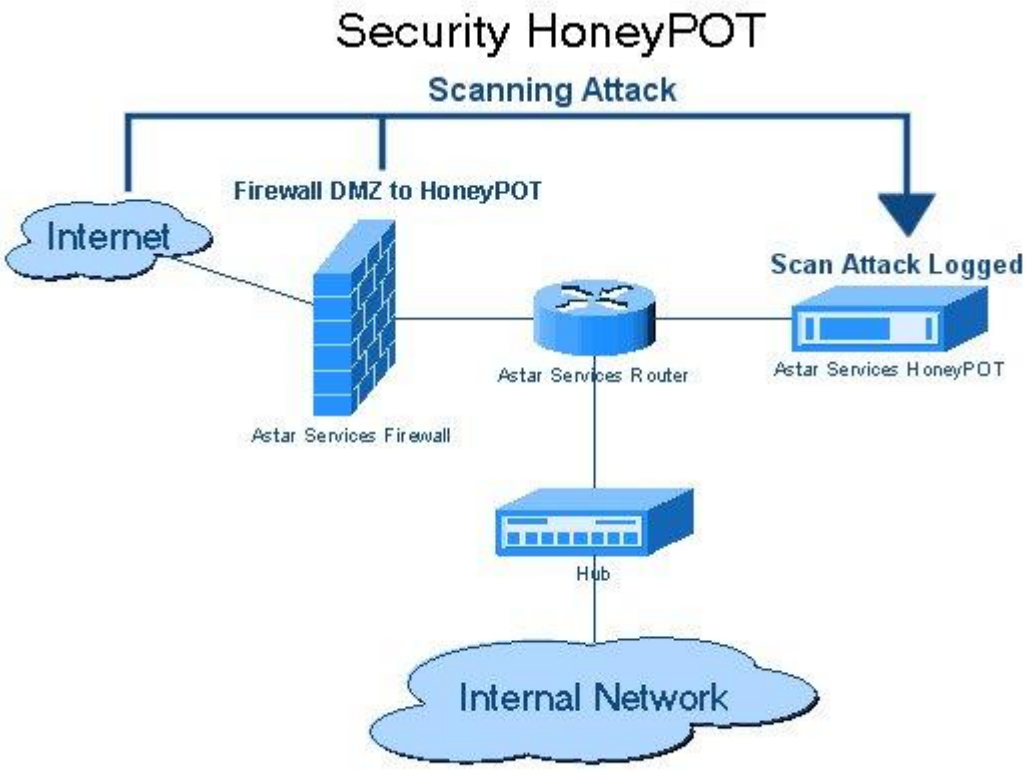
To improve the security of your wireless network, explore the several types of network security protocols, the ways you can strengthen Wi-Fi networks, and the security measures targeted for particular settings. Also, examine the tools and solutions available for increasing your network resilience

6.2.7. Honeypots:=>

The definition of a honeypot

A honeypot is a fake computer system set up to catch hackers and learn how they attack.

A honeypot is a computer or network set up to look like an easy target for hackers, but it is actually used to catch and study them.



se

It's a sacrificial computer system that's intended to attract cyberattacks, like a decoy. (Sacrificial: The computer system is intentionally exposed to cyberattacks, knowing that it might be compromised, in order to learn from those attacks.

Decoy: The system is set up to look like a valuable target, but its real purpose is to lure attackers away from the actual valuable systems and to observe their techniques.) It mimics a target for hackers, and uses their intrusion attempts

to gain information about cybercriminals and the way they are operating or to distract them from other targets**.**

Flow of diagram of security honey pot:=>

1. **Internet to Astar Services Firewall**: When someone tries to connect to your network from the internet, their request first hits the Astar Services Firewall. This firewall decides whether the request is safe or suspicious.
2. **Firewall to Astar Services Router**: If the request passes the firewall's rules, it then goes to the Astar Services Router. This router directs the traffic to its intended destination.
3. **Router to Astar Services Honeypot**: Some of the traffic is routed to the Astar Services Honeypot. The honeypot is a fake system designed to look like a real, vulnerable target to attract attackers.
4. **Honeypot Interaction**: The router forward some of the traffic (potentially malicious) to the honeypot. The honeypot interacts with the attackers, logging their activities and tricks they try. This helps in understanding their tactics and techniques.
5. **Router to Hub**: Meanwhile, other traffic from the router goes to a Hub. The Hub is like a central connector that distributes data to different parts of the internal network.
6. **Hub to Internal Network**: The Hub sends the traffic to the internal network, which is where your real, secure systems are located.

Simple Summary:

- **Attacker's Traffic**: Comes from the internet.
- **Firewall**: Filters and decides what traffic can pass.
- **Router**: Directs the traffic to the honeypot or internal network.
- **Honeypot**: Attracts and records attacker's actions.
- **Hub**: Distributes traffic to different parts of the internal network.

The honeypot is used to monitor and analyze threats, while the rest of the internal network remains protected.

.

By monitoring traffic coming into the honeypot system, you can assess:

- where the cybercriminals are coming from
- the level of threat
- what modus operandi they are using
- what data or applications they are interested in
- how well your security measures are working to stop cyberattacks

6.2.8 Traffic flow security :=>

Traffic flow :=>

Traffic flow carries data that is exchanged between the terminals during a communication service. In addition to unidirectional flows from a sender to a receiver, multicast or broadcast flows distribute data from a source to many destinations via splitting points in switching nodes of the network.

Traffic-flow security:=>

Traffic-flow security is the use of measures that conceal the presence and properties of valid messages on a network to prevent traffic analysis. This can be done by operational procedures or by the protection resulting from features inherent in some cryptographic equipment.

Various methods implemented for traffic flow security

In information security, various methods are used to ensure the security and integrity of network traffic. Here are some common methods:

1. **Firewalls**: Firewalls monitor and control incoming and outgoing network traffic based on predetermined security rules. They can be hardware-based, software-based, or a combination of both.
2. **Intrusion Detection Systems (IDS)**: IDS monitors network traffic for suspicious activity or known threats and alerts administrators to potential security incidents.
3. **Intrusion Prevention Systems (IPS)**: Similar to IDS, but with the added capability to actively block or prevent malicious traffic in real-time.
4. **Virtual Private Networks (VPNs)**: VPNs create a secure, encrypted connection over a less secure network, like the internet, to protect data in transit and ensure privacy.
5. **Traffic Encryption**: Encryption methods, such as TLS/SSL, secure data by converting it into a coded format that can only be deciphered by authorized parties.
6. **Access Control Lists (ACLs)**: ACLs define which users or systems are allowed to access specific resources or network segments, helping to restrict unauthorized access.
7. **Network Segmentation**: Dividing a network into smaller, isolated segments to limit the spread of attacks and improve overall security by controlling traffic between segments.

6.3 Firewalls

6.3.1. Design and Types of Firewalls

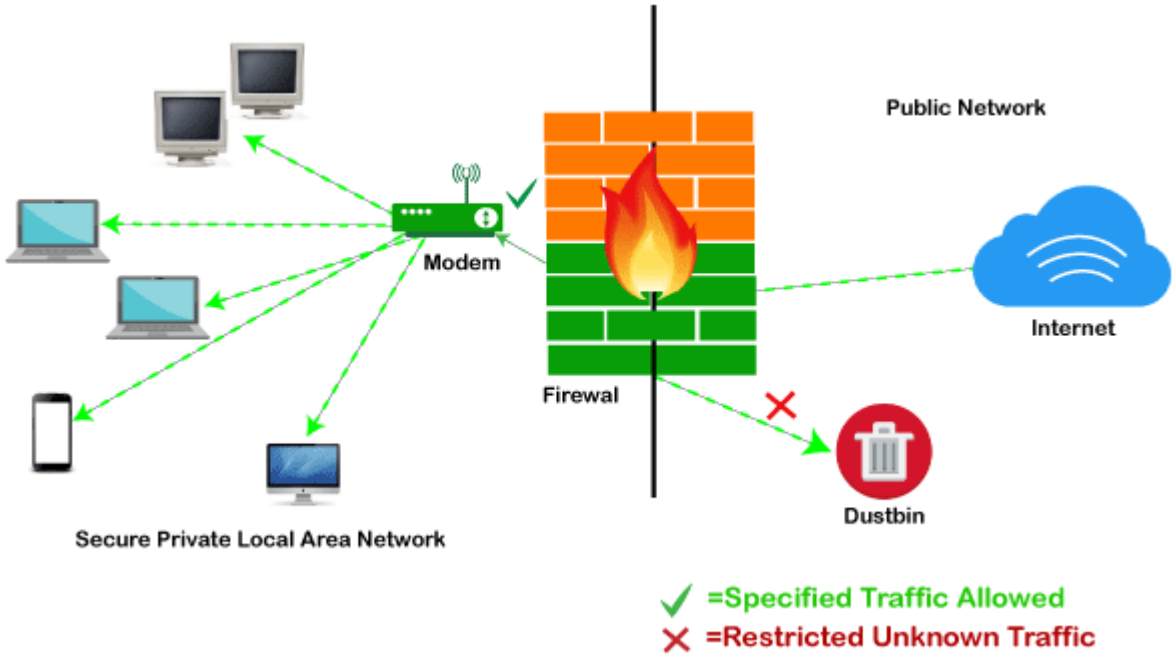
6.3.2. Personal Firewalls

6.3.3. Intrusion Detection System (IDS) and its types

6.3.4. Intrusion Protection System (IPS)

6.3 Firewall =>

A firewall is a network security device that monitors incoming and outgoing network traffic (Network traffic generally refers to the flow of data packets being sent and received over a network and flow of users can impact network traffic) and decides whether to allow or block specific traffic based on a defined set of security rules. Firewalls have been a first line of defense in network security for over 25 years. Firewalls establish a barrier between a trusted internal network and untrusted external networks, such as the internet.



How It Works:

- **Firewall's Role:**
  - The firewall acts as a barrier that filters traffic entering and leaving the LAN.
  - It inspects incoming traffic from the WAN (Internet) and only allows traffic that meets specific security criteria.
  - It also monitors outgoing traffic from the LAN to ensure that sensitive data is not sent out without authorization.
  - It can block malicious traffic, unauthorized access, and prevent attacks like DoS (Denial of Service **)where(**A Denial of Service (DoS) attack is a malicious attempt to disrupt the normal functioning of a targeted server, service, or network by overwhelming it with a

flood of internet traffic. The goal is to render the target unavailable to its intended users by consuming its resources such as bandwidth, memory, or processing power.)

Function of firewall:=>

A firewall is a security system designed to prevent unauthorized access into or out of a computer network. Firewalls are often used to make sure internet users without access are not able to interface (communicate)with private networks, or intranets, connected to the internet.

Benefits of firewalls include:

- Monitoring and filtering network traffic.
- Preventing virus infiltration.
- Blocking unauthorized access.
- Upholding data privacy.
- Enhancing compliance adherence(ensuring that the organization's network security measures meet regulatory and industry standards)
- Enhanced user identity protection.
- Control over application use.
- Encrypted traffic security without privacy compromise.

6.3.1 Types of firewall:=>

Firewalls can be classified into several types based on their function, implementation, and the technology they use.

⇨ Packet-Filtering Firewalls:

- Inspect individual packets of data and either allow or block them based on predefined rules.
- Operate at the network layer (Layer 3) of the OSI model.

⇨ Stateful Inspection Firewalls:

- Monitor the state of active connections and make decisions based on the context of the traffic (stateful).
- Operate at the network and transport layers (Layers 3 and 4) of the OSI model.

⇨ Proxy Firewalls (Application-Level Gateways):

- Act as intermediaries between users and the services they access.
- Inspect and filter traffic at the application layer (Layer 7) of the OSI model.

⇨ Next-Generation Firewalls (NGFWs):

- Combine traditional firewall functions with additional features like intrusion prevention, deep packet inspection, and application awareness.
- Operate across multiple layers of the OSI model, including the application layer (Layer 7).

⇨ Unified Threat Management (UTM) Firewalls:

- Provide a comprehensive security solution that includes firewall functions, intrusion detection/prevention, antivirus, content filtering, and more.
- Designed to be an all-in-one security appliance.

⇨ Network Address Translation (NAT) Firewalls:

- Modify network address information in packet headers to hide internal network addresses.
- Help protect internal networks by masking the IP addresses of devices.

⇨ Cloud Firewalls (Firewall-as-a-Service):

- Hosted in the cloud and provide firewall capabilities as a service.
- Suitable for protecting cloud-based infrastructure and applications.

⇨ Virtual Firewalls:

- Software-based firewalls that run on virtualized environments.
- Used to protect virtual machines and cloud environments.

⇨ Web Application Firewalls (WAFs):

- Specifically designed to protect web applications by filtering and monitoring HTTP/HTTPS traffic.
- Protect against common web-based attacks like SQL injection, cross-site scripting (XSS), and more.

Example of firewalls:=>

An example of a firewall is the Windows Firewall that comes bundled with Microsoft Windows operating systems. It is a software-based firewall that can help protect computers from unauthorized access and malware attacks by blocking incoming and outgoing network traffic.

Firewall Delivery Methods:

- Software firewalls
- Hardware firewalls
- Cloud firewalls

6.3.1 DESIGN OF FIREWALL:=>

How Does Firewall Design Work?

The five sequential steps to follow when designing a firewall include:

1. Identify security requirements for the organization: => Evaluate security requirements, assess security posture and use the information in defining the security requirements.
2. Define an overall security policy.: =>A well-defined security policy includes network resources, access policies and authorization controls and ensures that the firewall addresses all security requirements.
3. Define a firewall philosophy.: =>Identifying resources, applications, and services to be protected against threats from outside the organization and insider attacks makes it easier to define and configure the firewall.
4. Identify permitted communications: => Define an acceptable use policy to specify the types of network activities such as applications that are allowed and denied on the LAN and the Internet Web services.
5. Identify the firewall enforcement points:=> Determining enforcement points is fundamental to firewall design. Firewalls are deployed at the edge, between the private LAN and a public network, such as the Internet.

   Note: enforcement points" refers to specific locations within a network where a firewall needs to be placed to effectively monitor, control, and protect network traffic.

6.3.2. Personal Firewalls:=>

A personal firewall is a software app that monitors and manages network traffic going to and coming from a computer or other device. The personal

firewall protects an individual device by working as a sort of firewall that filters and checks traffic, unauthorized access, and other security risks**.**

What is personal or host based firewall?

A host-based firewall is installed directly on individual networked devices to filter network traffic on a single device by inspecting both incoming and outgoing data. Larger enterprises use this to manage the spread of malware throughout a network in the event that one device is infected.

Purpose of personal firewall

:=>

It protects your personal devices from unauthorized access and cyber threats, especially with the increasing number of connected devices in homes. A firewall is particularly important if you handle sensitive information or engage in activities that require enhanced privacy and security.

Advantages and disadvantages of personal firewall

Advantages of Personal Firewalls

- ⇨ Enhanced Security: Blocks unauthorized access and prevents malicious attacks.
- ⇨ Customizable Protection: Allows users to tailor settings to their specific needs.
- ⇨ Real-time Monitoring: Continuously monitors and alerts users to suspicious activities.
- ⇨ User-Friendly Interface: Easy to manage even for users with limited technical knowledge.

Disadvantages of Personal Firewalls

- ⇨ Resource Consumption: Can slow down system performance due to high resource use.
- ⇨ Potential for Misconfiguration: Incorrect settings can lead to security vulnerabilities.

- ⇨ Limited Scope: Only protects individual devices, not entire networks.
- ⇨ False Positives: May block legitimate applications, causing user inconvenience.

6.3.3. Intrusion Detection System (IDS) and its types

Intrusion

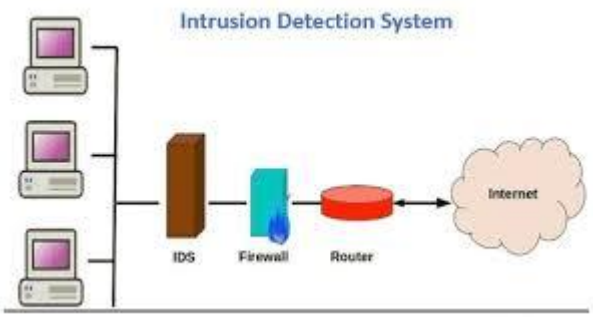
•- Any malicious activity or policy violations, that subsequently breaches (violates)security is an intrusion

Intrusion detection

- ➢ the act of detecting actions that attempt to compromise (Compromise" generally means to come to a mutual agreement where each party makes concessions and concessions means giving up something) the confidentiality, integrity or availability of a resource.

- ➢ the goal of intrusion detection is to identify entities attempting to subvert in-place security controls.(The goal of intrusion detection is to find people or things trying to break through security measures)

An intrusion detection system (IDS) is a network security tool that monitors network traffic and devices for known malicious activity, suspicious activity or security policy violations.



Firewall vs Intrusion detection system

A firewall blocks unauthorized access to a network, while an intrusion detection system (IDS) monitors and alerts on suspicious activity within the network.

5 Different Types of Intrusion Detection Systems

Although all intrusion detection systems fulfill the same purpose, they work in slightly different ways. Altogether, there are five IDS types. Let's explore the details, advantages, and drawbacks of each one.

1. Network Intrusion Detection System

A Network Intrusion Detection System (NIDS) is a solution that monitors your entire network through one or more touchpoints. To use a NIDS, you generally need to install it on a piece of hardware within your network infrastructure. Once installed, your NIDS will sample every packet (a collection of data) that passes through it.

NIDSs are beneficial because:

- They can analyze all inbound and outbound traffic

- They detect events in real-time, allowing for quick response times
- They're more challenging for intruders (attackers) to detect
- They can be strategically placed in critical areas

However, NIDSs aren't perfect. Potential downsides include:

- Hands-on maintenance – Because a NIDS is typically installed on a dedicated piece of hardware, you may need to spend more time manually interacting with it.
- Low specificity – The more traffic a NIDS tool analyzes, the more likely it is to lack specificity and miss signs of an intrusion.

2. Network Node Intrusion Detection System

A Network Node Intrusion Detection System (NNIDS) is technically a variation of a NIDS, but since it works differently, we'll consider it a different type of IDS.

A NNIDS also analyzes the packets that pass through it. However, instead of relying on a central device to monitor all network traffic, the system watches over each node connected to your network.

This differentiation comes with several benefits, such as:

- Higher speeds – Since the amount of traffic each NNIDS agent analyzes is reduced, the system can work faster.
- Taking up fewer resources – In the same vein, NNIDS uses fewer system resources. As such, you can easily install it on your current servers.

The main drawback of opting for a NNIDS is the need for multiple installations. While a NIDS only requires one device, NNIDS needs several—one for every server you want to monitor. Additionally, all of these NNIDS agents need to report to a central dashboard.

3. Host Intrusion Detection System

A Host Intrusion Detection System (HIDS) takes the device independence of NNIDS one step further. With a HIDS, you can install IDS software on every device connected to your network.

HIDSs work by taking "snapshots" of their assigned device. By comparing the most recent snapshot to past records, the HIDS can identify the differences that could indicate an intrusion. (Unfortunately, Host Intrusion Detection Systems (HIDS) often detect problems only after they have happened because they depend on logs that record intrusions. This can make your response time slower. Therefore, using HIDS effectively means you need to monitor it frequently.

4o
)

HIDSs are advantageous because:

- They can be installed on computers or servers
- They can pinpoint the affected device
- They notify administrators if analytical system files were modified or deleted
- They're particularly effective against insider threats

Unfortunately, HIDS solutions can suffer from "after-the-fact" monitoring. Because many HIDS solutions rely on logs that record intrusions, your mean time to respond (MTTR) may be slower overall. As such, proper use of an HIDS requires frequent monitoring.(Unfortunately, Host Intrusion Detection Systems (HIDS) often detect problems only after they have happened because they depend on logs that record intrusions. This can make your response time slower. Therefore, using HIDS effectively means you need to monitor it frequently.)

4. Protocol-Based Intrusion Detection System

A Protocol-Based Intrusion Detection System (PIDS) is a specific IDS that monitors the protocol in use. In practice, this system typically analyzes the HTTP or HTTPS protocol stream between your devices and the server.

In most cases, a PIDS will go at the front end of a server. The system can protect your web server by monitoring inbound and outbound traffic.

Because they focus on the protocol (the way devices transmit information within a network), PIDSs aren't necessarily a comprehensive IDS solution. However, they can augment an already robust cybersecurity solution. (A Physical Intrusion Detection System (PIDS) isn't a complete security system on its own, but it can be a valuable addition to an existing strong cybersecurity setup, helping to further enhance protection)

5. **Application Protocol-Based Intrusion Detection System**

An Application Protocol-Based Intrusion Detection System (APIDS) is a type of IDS that specializes in software app security. Typically associated with host-based intrusion detection systems (HIDS), APIDSs monitor the communications that occur between applications and the server. An APIDS is typically installed on groups of servers.

As with a PIDS, an APIDS is unlikely to solve all of your network monitoring needs. Still, it can complement other types of IDS.

Steps involved in Intrusion Handling

- Preparation for an attack :=>

  This step occurs before any attacks are detected. It establishes procedures and mechanisms for detecting and responding to attacks.

- Identification of an attack :=> This triggers the remaining phases.

- Containment (confinement) of the attack :=> This step limits the damage as much as possible.

- Eradication of the attack :=>

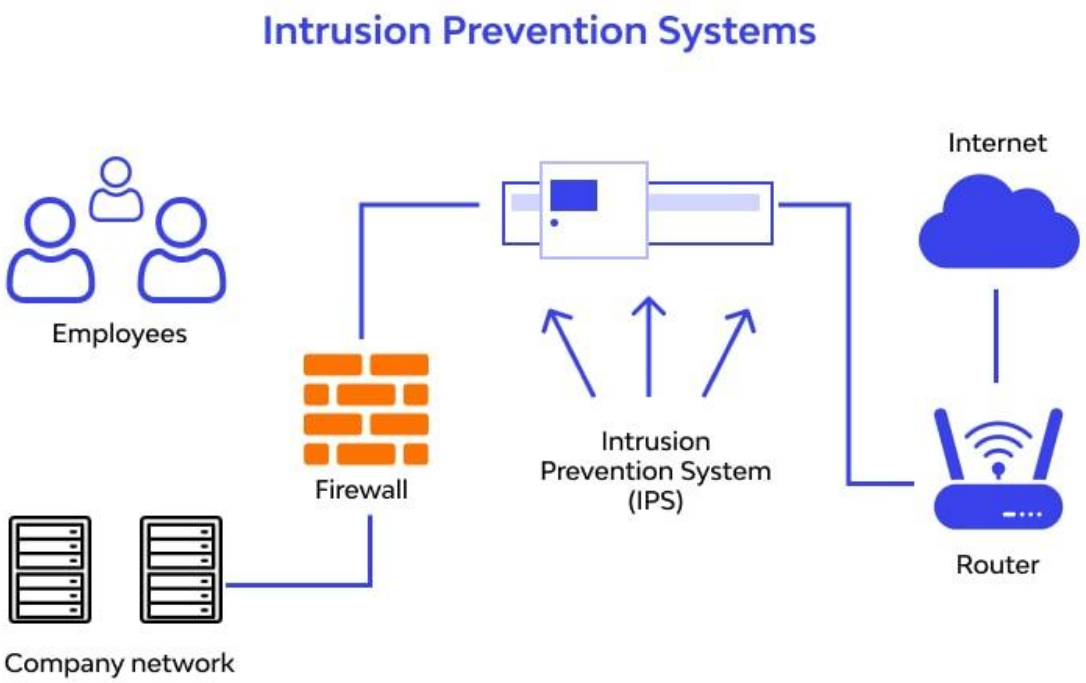
This step stops the attack and blocks further similar attacks.

- ⇨ Recovery from the attack :=> This step restores the system to a secure state (with respect to the site security policy).

- ⇨ Follow-up to the attack:=> This step involves taking action against the attacker, identifying problems in the handling of the incident, and recording lessons learned (or lessons not learned that should be learned).

6.3.4. Intrusion Protection System (IPS)

An intrusion prevention system (IPS) is a network security tool (which can be a hardware device or software) that continuously monitors a network for malicious activity and takes action to prevent it, including reporting, blocking, or dropping it, when it does occur.



6.4 Email Security

6.4.1 PGP

6.4.2 S/MIME

Email Security :=>

Email Security: => Email security is the practice of preventing email-based cyber-attacks, protecting email accounts from takeover (unauthorized access), and securing the contents of emails. Email security is multifaceted (many aspects) and may require several different layers of protection.

Email security is the process of preventing email-based cyberattacks and unwanted communications. It spans protecting inboxes from takeover, protecting domains from spoofing, stopping phishing attacks, preventing fraud, blocking malware delivery, filtering spam, and using encryption to protect the contents of emails from unauthorized persons.

(span means cover or includes all aspects)

Security enhancements are: =>

- Authentication (of sender of message)
- Confidentiality (protection from disclosure)
- Message integrity (protection from modification)
- Non-repudiation of origin (protection from denial by sender)

⇨ Two standard schemes(scheme means system or method for achieving a specific goal)

- PGP
- S/MIME

Here, PGP and S/MIME are method of secure email communication.

.

Why is email security important?

- **Protection Against Cyberattacks**: Email is a top goal for cybercriminals. Malware, phishing attacks, and other threats often arrive via email. In fact, 94% of malware is delivered through email channels1. By implementing robust email security measures, organizations can defend against these threats.

- **Reducing Risk:** Cybersecurity incidents can have devastating consequences, including financial losses, operational disruptions, and damage to an organization's reputation. Effective email security helps protect your brand, reputation, and bottom line.

- **Compliance**: Email security ensures compliance with data protection laws like GDPR and HIPAA. By safeguarding sensitive information, organizations avoid legal fines and other intangible costs associated with cyberattacks.

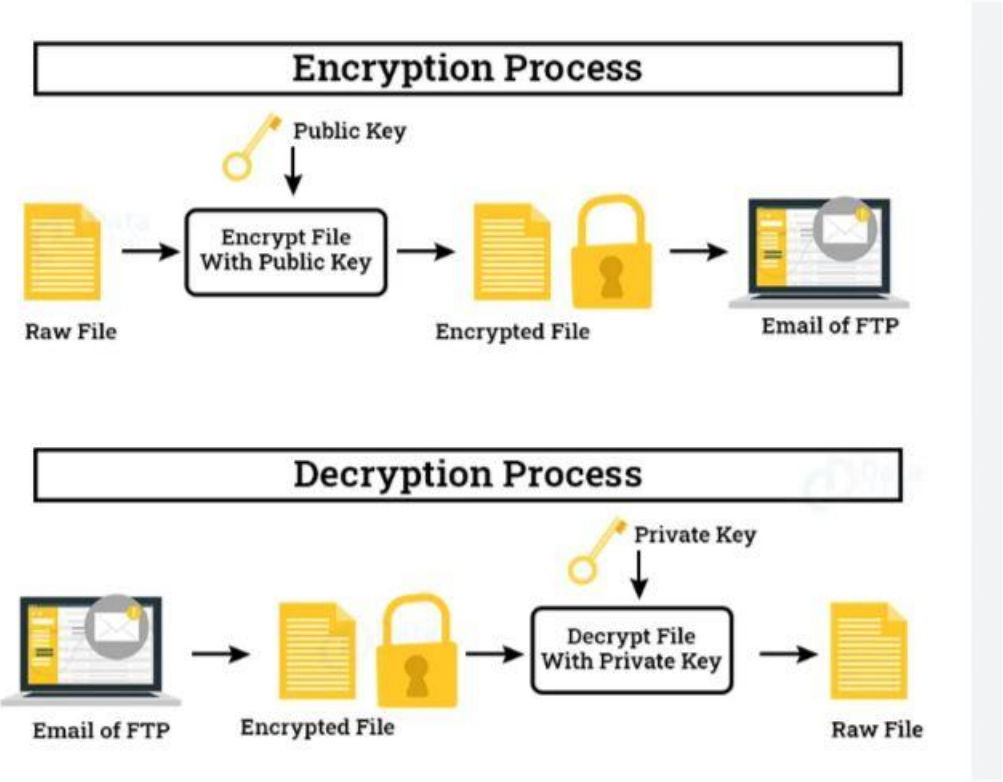
- **Productivity Enhancement**: With email security in place, disruptions caused by threats like phishing emails are minimized. This allows organizations to focus more on business growth and less on handling security incidents

6.4.**1. PGP** :=>

Pretty Good Privacy (PGP) is a security program used to decrypt and encrypt email and authenticate email messages through digital signatures and file encryption.

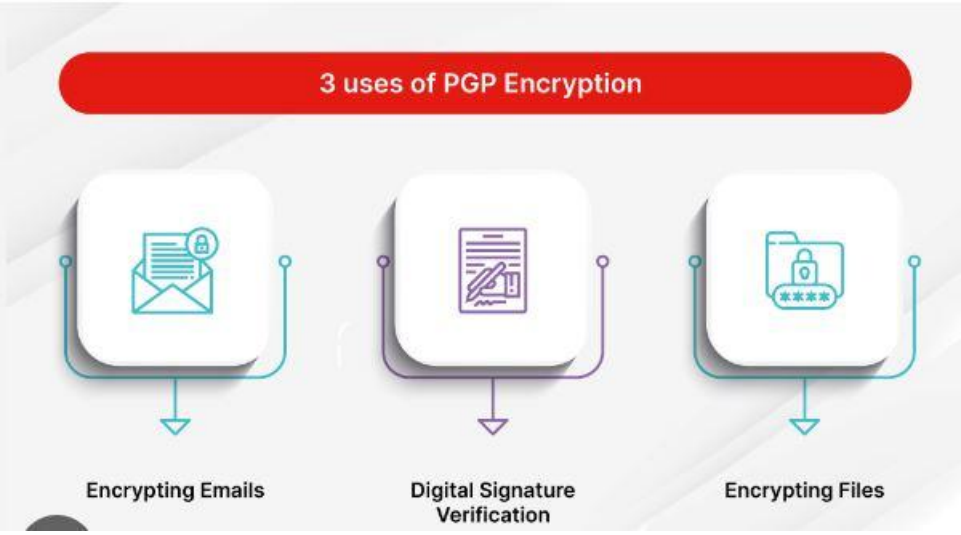
Five principles of PGP

PGP was designed to provide all four aspects of security, i.e., privacy, integrity, authentication, and non-repudiation in the sending of email. PGP uses a digital signature (a combination of hashing and public key encryption) to provide integrity, authentication, and non-repudiation.



6.4.1 PGP:=>

PGP is short for Pretty Good Privacy, a security program that enables users to communicate securely by decrypting and encrypting messages, authenticating messages through digital signatures, and encrypting files. It was one of the first freely available forms of public-key cryptography software.



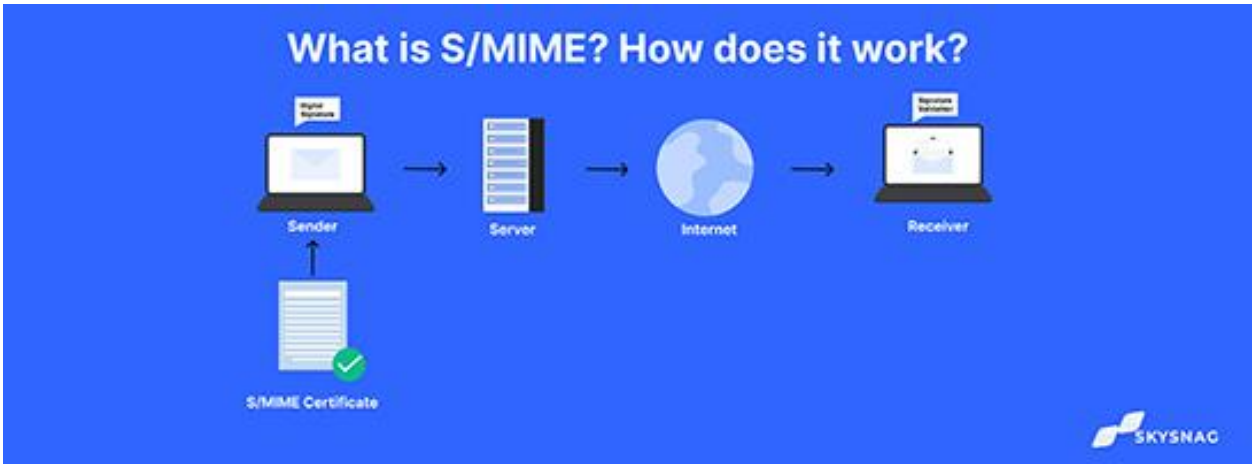
Pretty Good Privacy (PGP) is an encryption system used for both sending encrypted emails and encrypting sensitive files.

The popularity of PGP is based on two factors. The first is that the system was originally available as freeware, and so spread rapidly among users who wanted an extra level of security for their email

messages. The second is that since PGP uses both symmetric encryption and public-key encryption, it allows users who have never met to send encrypted messages to each other without exchanging private encryption keys.

6.4.2 S/MIME

=> S/MIME (Secure/Multipurpose Internet Mail Extensions) is a standard for public-key encryption and signing of MIME data



Secure/Multipurpose Internet Mail Extensions (S/MIME)

¬security enhancement to MIME email

● ¬S/MIME is very similar to PGP in the sense that both offer the ability to sign and/or encrypt messages.

S/MIME has emerged as the industry standard for commercial and organizational use.

● PGP still remains as the choice for personal e-mail security for many users.

¬Email evolution: ●

● Original Email + MIME = MIME Email

- MIME Email + Security = S/MIME

Here's a simpler explanation of S/MIME functions:

Enveloped Data: This means that the content (like an email) is encrypted to keep it secret, and the key used for encryption is also encrypted to ensure only the intended recipient can decrypt it.

Signed Data: This involves creating a digital signature of the content to prove it's authentic and hasn't been tampered with. This signature is encrypted with the sender's private key. The content and the signature are then encoded into a format that can be sent over email.

Clear-Signed Data: The content is signed to verify its authenticity, but only the signature is encoded. The content itself is left in plain text, so anyone can read it, but the signature helps prove it came from the sender and hasn't been altered.

Signed & Enveloped Data: You can combine these methods. For example, you can encrypt signed data to keep it secret, or you can sign encrypted data to verify its source and integrity. This allows for multiple layers of security.

Feature	PGP (Pretty Good Privacy)	S/MIME (Secure/Multipurpose Internet Mail Extensions)
Purpose	Email encryption and signing	Email encryption and signing
Standard	Not a formal standard, but widely used	Based on public standards (X.509, MIME)
Key Management	Web of Trust	Hierarchical Public Key Infrastructure (PKI)
Certificate Issuance	Self-generated certificates	Certificates issued by Certificate Authorities (CAs)
Interoperability	Requires compatible PGP software	Built into many email clients and widely supported
Encryption Algorithm	Supports multiple algorithms (e.g., RSA, DSA)	Typically uses RSA and other standardized algorithms
Ease of Use	Requires more manual configuration	Often integrated into email clients for easier use
Trust Model	Decentralized trust model	Centralized trust model
Adoption	Popular among privacy-focused users	Widely adopted in enterprise environments
Compatibility	Can be used with various email systems	Standardized, better compatibility with major clients
Revocation	Revocation handled through keyservers	Revocation handled through Certificate Revocation Lists (CRLs) and Online Certificate Status Protocol (OCSP)

OR: PGP VS S/MIME->

:=>

Here are the key differences between PGP and S/MIME in single-sentence explanations:

Purpose: PGP and S/MIME both aim to secure email through encryption and signing, but PGP is more commonly used by individuals for privacy, whereas S/MIME is widely adopted in corporate environments.

Standard: PGP is not a formal standard but is widely used, while S/MIME is based on established public standards like X.509 and MIME.

Key Management: PGP uses a Web of Trust model for key management, relying on users to sign each other's keys, while S/MIME uses a hierarchical PKI model with certificates issued by trusted Certificate Authorities.

Certificate Issuance: PGP allows users to self-generate certificates, whereas S/MIME requires certificates to be issued by Certificate Authorities.

Interoperability: PGP requires compatible PGP software for use, while S/MIME is built into many email clients, offering broader interoperability.

Encryption Algorithm: PGP supports multiple encryption algorithms like RSA and DSA, while S/MIME typically uses standardized algorithms like RSA.

Ease of Use: PGP often requires more manual configuration, whereas S/MIME is often integrated into email clients, making it easier to use.

Trust Model: PGP employs a decentralized trust model, relying on a web of user trust, whereas S/MIME uses a centralized trust model based on trusted Certificate Authorities.

Adoption: PGP is popular among privacy-focused users, while S/MIME is widely adopted in enterprise environments due to its integration and standardization.

Compatibility: PGP can be used with various email systems but may face compatibility issues, while S/MIME offers better compatibility with major email clients due to its standardized approach.